Amadey - APT-C-36 Lab

1. Kịch bản

- Cảnh báo ngoài giờ từ hệ thống EDR về hành vi đáng ngờ từ Win workstation. Malware này tương đồng với Amadey Trojan Stealer.

2. Volatility Tool

- filescan: tìm file đang mở, bị đóng hoặc xóa (miễn là vùng nhớ chưa bị ghi đè)
  - File đóng: ghi đè nếu thiếu RAM
  - File bị xóa: có thể cấp cho yêu cầu khác bất kì
- pslist: chỉ liệt kê process đang chạy
- pscan: cả tiến trình đang chạy, đã đóng hoặc tự ẩn giấu
- netscan: quét được cả kết nối đang mở và đóng
  - Kết nối đóng dễ dàng bị ghi đè (vì nhiều kết nối)

3. Write up

1. In the memory dump analysis, determining the root of the malicious activity is essential for comprehending the extent of the intrusion. What is the name of the parent process that triggered this malicious behavior?

- Yêu cầu: xác định nguồn gốc hành vi độc hại → hiểu mức độ xâm nhập
- As: lssass.exe
- Sử dụng hướng dẫn trong https://www.varonis.com/blog/how-to-use-volatility → đưa ra danh sách cây tiến trình, phát hiện tiến trình giả mạo tên lsass.exe để chạy → tiến trình độc hại
  - lssass.exe này đẻ ra tiến trình con là rundll32.exe - đây là tiến tình hệ thống để chạy file DLL (hành vi lạ)
- lsass.exe xịn được chạy từ **wininit.exe**

```
1356    1312    explorer.exe     0xfa8002cf5b30  21      685     1       False   2023-08-09 21:32:10.000000      N/A
* 1576  1356    vmtoolsd.exe     0xfa8002eb9630  6       183     1       False   2023-08-09 21:32:11.000000      N/A
3016    2144    GoogleCrashHan   0xfa800143eb30  5       91      0       True    2023-08-09 21:32:21.000000      N/A
3028    2144    GoogleCrashHan   0xfa8001bfe6f0  5       81      0       False   2023-08-09 21:32:21.000000      N/A
2748    2524    lssass.exe       0xfa800300a750  7       254     1       True    2023-08-09 21:33:04.000000      N/A
* 3064  2748    rundll32.exe     0xfa8003042b30  1       64      1       True    2023-08-09 21:33:56.000000      N/A
```

2. Once the rogue process is identified, its exact location on the device can reveal more about its nature and source. Where is this process housed on the workstation?

- Yêu cầu: Sau khi tìm được tiến trình, tìm vị trí chính xác để biết in4 về bản chất và nguồn gốc
- As: C:\Users\0XSH3R~1\AppData\Local\Temp\925e7e99c5\lssass.exe
- Thư mục: 0XSH3R~1 → tên dài bị cắt ngắt → dấu hiệu thư mục tạm thời
- Dùng đối số cmdline để tìm thông tin về các dòng lệnh xuất hiện
- Việc ghi vào thư mục Temp trong AppData cho thấy kẻ tấn công lợi dụng quyền đọc/ghi mức user đối với file trong thư mục này để tạo và thực thi file malware

```
2620    svchost.exe      C:\Windows\system32\svchost.exe -k LocalServiceAndNoImpersonation
3016    GoogleCrashHan   "C:\Program Files (x86)\Google\Update\1.3.36.292\GoogleCrashHandler.exe"
3028    GoogleCrashHan   "C:\Program Files (x86)\Google\Update\1.3.36.292\GoogleCrashHandler64.exe"
2748    lssass.exe       "C:\Users\0XSH3R~1\AppData\Local\Temp\925e7e99c5\lssass.exe"
3064    rundll32.exe     "C:\Windows\System32\rundll32.exe" C:\Users\0xSh3rl0ck\AppData\Roaming\116711e5a2ab05\clip64.dll, Main
2124    taskeng.exe      taskeng.exe {08C69956-101C-473F-92F2-258443DE915D}
2592    sppsvc.exe       C:\Windows\system32\sppsvc.exe
```

3. Persistent external communications suggest the malware's attempts to reach out C2C server. Can you identify the Command and Control (C2C) server IP that the process interacts with?

- Yêu cầu: xác định C2 server
- As: 41.75.84.12
- Dùng tham số windows.netscan để tìm thông tin các kết nối mạng

```
0x1e928010      TCPv6   ::      49155   ::      0       LISTENING       500     services.exe    -
0x1e94dcf0      TCPv4   192.168.195.136 49168   41.75.84.12     80      CLOSED  2748    lssass.exe      N/A
0x1e9846b0      UDPv4   192.168.195.136 68      *       0               768     svchost.exe     2023-08-09 21:50:07.000000
0x1e988840      UDPv4   0.0.0.0 5355    *       0               920     svchost.exe     2023-08-09 21:50:07.000000
```

4. Following the malware link with the C2C, the malware is likely fetching additional tools or modules. How many distinct files is it trying to bring onto the compromised workstation?

- Yêu cầu: kiểm tra kết nối với C2 để xem các file được đưa vào workstation
- As: 2
- Dùng tham số windows.memmap trích xuất toàn bộ vùng nhớ của PID 2748 ra file sau đó dùng grep để tìm kiếm

```
ubuntu@ip-172-31-25-155:~/Desktop/Start here/Tools/volatility3$ strings pid.2748
.dmp | grep "GET "
GET
GET /rock/Plugins/cred64.dll HTTP/1.1
GET /rock/Plugins/clip64.dll HTTP/1.1
ubuntu@ip-172-31-25-155:~/Desktop/Start here/Tools/volatility3$
```

- cred64.dll: thu thập in4 credential
- clip64.dll: thu thập thông tin clipboard (khay nhớ tạm)

5. Identifying the storage points of these additional components is critical for containment and cleanup. What is the full path of the file downloaded and used by the malware in its malicious activity?

- Yêu cầu: tìm vị trí các file được tải xuống → ngăn chặn và dọn dẹp
- As: C:\Users\0xSh3rl0ck\AppData\Roaming\116711e5a2ab05\clip64.dll
- 116711e5a2ab05 → thư mục ngẫu nhiên → triển khai payload động để phức tạp trong dọn dẹp malware

```
2748    lssass.exe      "C:\Users\0xSh3rl0ck\AppData\Local\Temp\925e7e99c5\lssass.
exe"
3064    rundll32.exe    "C:\Windows\System32\rundll32.exe" C:\Users\0xSh3rl0ck\A
ppData\Roaming\116711e5a2ab05\clip64.dll, Main
2124    taskeng.exe     taskeng.exe {08C69956-101C-473F-92F2-258443DE915D}
2592    sppsvc.exe      C:\Windows\system32\sppsvc.exe
```

- Dùng AppData\Roaming có khả năng đồng bộ nếu user login ở máy khác → năng khả năng phát tán malware

6. Once retrieved, the malware aims to activate its additional components. Which child process is initiated by the malware to execute these files?

- Yêu cầu: tìm tiến trình con chạy file thực thi đươc tải về
- As: rundll32.exe

7. Understanding the full range of Amadey's persistence mechanisms can help in an effective mitigation. Apart from the locations already spotlighted, where else might the malware be ensuring its consistent presence?

- Yêu cầu: hiểu cơ chế persistence → giảm thiểu thiệt hại
    - Malware có thể ẩn mình ở nới khác
- As: C:\Windows\System32\Tasks\lssass.exe
- Dùng tham số filescan để quét toàn bộ file → tìm file lssass.exe giấu ở nơi khác

```
ubuntu@ip-172-31-20-173:~/Desktop/Start here/Tools/volatility3$ python3 vol.py -f
/home/ubuntu/Desktop/'Start here'/Artifacts/'Windows 7 x64-Snapshot4.vmem' windows
.filescan | grep "lssass.exe"
0x517b290  100.0\Users\0XSH3R~1\AppData\Local\Temp\925e7e99c5\lssass.exe        21
6
0x1dad11e0      \Windows\System32\Tasks\lssass.exe      216
0x1e994b20      \Users\0XSH3R~1\AppData\Local\Temp\925e7e99c5\lssass.exe        21
6
ubuntu@ip-172-31-20-173:~/Desktop/Start here/Tools/volatility3$
```

- Malware persistence thường: nhúng vào thành phần hệ thống, thư mục khởi động, reg key, tác vụ theo lịch hoặc dịch vụ hệ thông
    - Ở đây thư mục Tasks → liên quan đến Windows Task Scheduler = auto tác vụ
    - Lợi dụng thành phần đáng tin này để tự đăng ký tác vụ và qua mặt công cụ giám sát bảo mật
    - Cần cấu hình file .job (HDH cũ) hoặc XML (HDH mới) để HDH biết khi nào cần kích hoạt tác vụ

4. Mitre ATTCK

1. **Execution**

- T1059.003: **Command and Scripting Interpreter: Windows Command Shell**
    - Lợi dụng cmd để chạy file

2. **Persistence**

- T1053.005: **Scheduled Task/Job: Scheduled Task**
    - Lạm dụng Win Task Schedule để lập lịch thực thi malware

3. **Privilege Escalation**

- T1053.005: **Scheduled Task/Job: Scheduled Task**
    - Attacker có quyền local Admin muốn lên quyền tối cao (NT AUTHO\SYSTEM) → tạo task có tham số /RU "SYSTEM"
    - Ghi đè file thực thi của task quyền SYSTEM hiện có nếu user có quyền ghi

4. **Defense Evasion**

- T1218.011: **System Binary Proxy Execution: Rundll32**
    - Ẩn mình trong rundll32.exe để thực thi thay vì chạy trực tiếp để qua mặt công cụ bảo mật
- T1036.005: **Masquerading: Match Legitimate Resource Name or Location**
    - Sao chéo hoặc đặt tên gần giống tên/vị trí của file, reg key, các tài nguyên khác để né tránh phòng thủ

5. **Command and Control**

- T1071.001: **Application Layer Protocol: Web Protocols**
    - Sử dụng giao thức HTTP/S để liên lạc
- T1105: **Ingress Tool Transfer**
    - Vận chuyển file, tool thông qua dịch vụ web ở trên

6. **<u>Exfiltration</u>**

- T1041: **Exfiltration Over C2 Channel**
    - Vận chuyển data lấy đươc qua kênh C2